

ENCUESTA INTEGRAL DREAD

Evaluación de Indicadores y Métricas de Ciberseguridad en Organizaciones

Kit de Evaluación DREAD • Edición 2025–2026 • España y Contexto Internacional

"Una encuesta bien diseñada no interroga: conversa. No acusa: invita a pensar."

Esta encuesta está concebida como un instrumento de diagnóstico estratégico, no como un examen. Cada respuesta aporta valor — incluso (y especialmente) las que revelan las lagunas.

INSTRUCCIONES GENERALES

Tiempo estimado de cumplimentación: 45–75 minutos (versión completa) / 20–30 minutos (versión abreviada, secciones marcadas con ★)

Confidencialidad: Todas las respuestas son estrictamente confidenciales y se tratarán de forma anonimizada y agregada. Los datos individuales no serán publicados ni compartidos con terceros.

Cómo responder: Para cada pregunta, seleccione la opción que **mejor describe la situación actual** de su organización, no la situación ideal ni la prevista. La honestidad es el único requisito metodológico irrenunciable.

Escala de madurez de referencia (cuando aplique):

- **1 — Inexistente:** No existe proceso, política ni evidencia de práctica.
- **2 — Inicial/Ad hoc:** Se hace de forma reactiva, sin documentar ni sistematizar.
- **3 — Definido:** Existe proceso documentado, pero su aplicación es irregular.
- **4 — Gestionado:** Proceso sistemático con métricas básicas de seguimiento.
- **5 — Optimizado:** Proceso integrado, medido, mejora continua demostrable.

BLOQUE 0 — PERFIL ORGANIZATIVO

(Datos de contexto, no evaluativos)

P0.1 ★ — Sector de actividad principal

¿En qué sector opera principalmente su organización? (marque uno)

- ☐ Administración Pública (central, autonómica o local)
- ☐ Banca, seguros y servicios financieros
- ☐ Energía, agua y suministros esenciales
- ☐ Salud y servicios sanitarios
- ☐ Transporte y logística
- ☐ Telecomunicaciones e infraestructura digital
- ☐ Industria manufacturera y fabricación
- ☐ Comercio electrónico y retail
- ☐ Educación e investigación
- ☐ Defensa y seguridad nacional
- ☐ Tecnología y servicios TI
- ☐ Otro: _____

P0.2 ★ — Tamaño de la organización

Número aproximado de empleados:

- ☐ Menos de 10 (microempresa)
- ☐ 10–49 (pequeña empresa)
- ☐ 50–249 (mediana empresa)
- ☐ 250–999 (empresa grande)
- ☐ 1.000–4.999 (gran corporación)
- ☐ 5.000 o más (corporación de gran escala / entidad pública amplia)

P0.3 — Rol del encuestado

¿Cuál es su responsabilidad principal en la organización?

- ☐ CISO / Responsable de Seguridad de la Información
- ☐ CIO / Director de Tecnología
- ☐ CTO / Director Técnico
- ☐ DPO / Delegado de Protección de Datos
- ☐ Responsable de Riesgos o Cumplimiento
- ☐ Auditor interno de TI/ciberseguridad
- ☐ Analista o técnico de seguridad (sin responsabilidad directiva)
- ☐ Director General / CEO / Consejo de Administración
- ☐ Otro: _____

P0.4 ★ — Madurez general percibida en ciberseguridad

Antes de entrar en detalles: ¿cómo calificaría la madurez global de ciberseguridad de su organización?

- ☐ 1 — Estamos empezando, hay mucho por hacer
- ☐ 2 — Tenemos lo básico, pero de forma reactiva
- ☐ 3 — Hemos formalizado procesos clave aunque con lagunas
- ☐ 4 — Gestionamos con métricas y revisión regular
- ☐ 5 — Somos referencia del sector; mejoramos continuamente

P0.5 — Operador de servicios esenciales o importante (NIS2)

¿Ha sido identificada su organización como Entidad Esencial o Entidad Importante bajo la Directiva NIS2 / Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad (España, 2025)?

- ☐ Sí, como Entidad Esencial
- ☐ Sí, como Entidad Importante
- ☐ No, no aplica a nuestra organización
- ☐ En proceso de determinación / pendiente de notificación
- ☐ Desconozco si nos aplica

BLOQUE 1 — CONOCIMIENTO Y ADOPCIÓN DEL MARCO DREAD

(Línea base de familiaridad metodológica)

P1.1 ★ — Conocimiento del marco DREAD

¿Con qué profundidad conoce el marco DREAD como metodología de evaluación de amenazas?

- ☐ No lo conozco / Es la primera vez que escucho este nombre
- ☐ Lo he oído mencionar, pero no sé bien en qué consiste
- ☐ Conozco sus dimensiones básicas (Daño, Reproducibilidad, Explotabilidad, Usuarios Afectados, Descubribilidad)
- ☐ Lo aplico de forma puntual o ad hoc en algunos proyectos
- ☐ Es parte formal de nuestra metodología de gestión de riesgos documentada
- ☐ Lo integramos con otros frameworks (CVSS, STRIDE, FAIR, MITRE ATT&CK) de forma sistemática

P1.2 — Frameworks de evaluación de riesgos utilizados

*¿Qué marcos o metodologías utiliza actualmente su organización para evaluar y priorizar amenazas?
(Marque todos los que apliquen)*

- ☐ DREAD (Damage, Reproducibility, Exploitability, Affected Users, Discoverability)
- ☐ CVSS v3.x / CVSS v4.0 (Common Vulnerability Scoring System)
- ☐ STRIDE + modelado de amenazas
- ☐ OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation)
- ☐ PASTA (Process for Attack Simulation and Threat Analysis)
- ☐ FAIR (Factor Analysis of Information Risk)
- ☐ MITRE ATT&CK para priorización táctica
- ☐ EPSS (Exploit Prediction Scoring System)
- ☐ Metodología propia / interna
- ☐ MAGERIT / Herramienta PILAR (CCN-CERT)
- ☐ Ningún framework formalizado
- ☐ Otro: _____

P1.3 — Razones para no usar DREAD (o usarlo limitadamente)

*Si DREAD no forma parte de su práctica habitual, ¿cuál es el principal motivo?
(Responda solo si no usa DREAD de forma regular; de lo contrario, pase a P1.4)*

- ☐ Desconocimiento del marco
- ☐ Percepción de que es demasiado subjetivo / inconsistente entre analistas
- ☐ Preferencia por CVSS, que está más estandarizado
- ☐ Falta de herramientas de soporte (no hay software que lo automatice bien)
- ☐ No tenemos equipo de seguridad con capacidad para aplicarlo
- ☐ El coste de implementación supera el beneficio percibido
- ☐ La dirección no lo considera prioritario
- ☐ Ya fue descontinuado por Microsoft; no nos inspira confianza
- ☐ Otro: _____

P1.4 — Variantes o extensiones de DREAD conocidas

*¿Conoce o utiliza alguna de las siguientes variantes o extensiones del modelo DREAD?
(Marque todas las que apliquen)*

- ☐ DREAD-D (sin la dimensión de Descubribilidad, para evitar "security by obscurity")
- ☐ DREAD ponderado (con pesos diferenciales por dimensión según contexto)
- ☐ Fuzzy DREAD (con lógica difusa y números triangulares para tratar incertidumbre)
- ☐ DREAD integrado con machine learning / automatización
- ☐ DREAD combinado con CVSS para scoring híbrido
- ☐ DREAD escalado a nivel nacional / territorial
- ☐ Ninguna de las anteriores
- ☐ Otra variante: _____

BLOQUE 2 — INDICADOR D: DAÑO POTENCIAL

(Damage Potential)

"El daño más temible no es el que se ve venir, sino el que se materializa en silencio."

P2.1 ★ — Evaluación del daño potencial en su organización

¿Cómo evalúa actualmente el daño potencial que una amenaza podría causar a su organización?

- ☐ No evaluamos el daño potencial de forma sistemática
- ☐ Usamos criterios cualitativos informales (alto/medio/bajo según percepción del analista)
- ☐ Empleamos una escala numérica (ej.: 1-10) con criterios documentados
- ☐ Usamos CVSS como proxy para el daño (componentes C/I/A: Confidencialidad, Integridad, Disponibilidad)
- ☐ Cuantificamos el daño en términos financieros (pérdida estimada en euros) mediante FAIR o equivalente
- ☐ Integramos múltiples dimensiones: financiero, reputacional, regulatorio y de continuidad operativa

P2.2 — Sub-indicadores de Daño considerados

¿Cuáles de las siguientes dimensiones de daño incorpora su proceso de evaluación? (Marque todas las que apliquen)

- ☐ Pérdida o robo de datos sensibles (personales, financieros, estratégicos)
- ☐ Interrupción de servicios o procesos críticos (disponibilidad)
- ☐ Daño a la integridad de datos o sistemas
- ☐ Impacto reputacional y de confianza del cliente
- ☐ Consecuencias regulatorias (sanciones GDPR, NIS2, ENS, DORA)
- ☐ Pérdidas financieras directas (fraude, extorsión por ransomware)
- ☐ Impacto en vidas humanas (entornos OT/sanitarios/infraestructura crítica)
- ☐ Impacto en la cadena de suministro
- ☐ Impacto sobre terceros o ciudadanos (si opera servicios esenciales)
- ☐ Daño en el PIB sectorial o nacional

P2.3 — Puntuación de Daño en los últimos incidentes significativos

Pensando en el incidente de ciberseguridad más relevante sufrido en los últimos 24 meses, ¿cómo calibraría el Daño causado?

- ☐ No hemos tenido incidentes significativos (o no tenemos constancia de ello)
- ☐ Daño mínimo: impacto contenido, sin afectación a datos sensibles ni servicios críticos
- ☐ Daño bajo: interrupción temporal de servicios no críticos, recuperación rápida
- ☐ Daño moderado: afectación a datos o servicios importantes, recuperación en días
- ☐ Daño alto: compromiso de datos sensibles, interrupción prolongada de operaciones críticas
- ☐ Daño crítico: pérdida masiva de datos, extorsión exitosa, impacto regulatorio severo, o afectación a terceros/ciudadanos
- ☐ Prefiero no responder / información confidencial

P2.4 — Integración del Daño con requisitos regulatorios

¿Vincula su evaluación de Daño con las obligaciones de notificación de incidentes establecidas por la normativa aplicable?

- ☐ No, la evaluación técnica y el cumplimiento regulatorio son procesos separados
- ☐ Parcialmente: alertamos a compliance cuando el incidente es "evidente", pero sin criterio formalizado
- ☐ Sí, tenemos umbrales de Daño definidos que activan el proceso de notificación a la AEPD / INCIBE / CCN-CERT / regulador sectorial
- ☐ Sí, y además hemos mapeado los niveles de Daño DREAD con los umbrales de significatividad de NIS2 / ENS / DORA
- ☐ Tenemos un proceso automatizado de triaje que clasifica incidentes por Daño y activa flujos de notificación según normativa

P2.5 — Capacidad de cuantificación financiera del daño

¿Es capaz su organización de estimar el coste económico de un incidente de ciberseguridad antes de que ocurra (análisis ex ante)?

- ☐ No, no tenemos capacidad de cuantificación financiera del riesgo cyber
- ☐ Tenemos estimaciones muy aproximadas basadas en el coste de incidentes pasados
- ☐ Usamos benchmarks del sector (ej.: coste medio por brecha en España o en la UE)
- ☐ Aplicamos modelos actuariales o financieros (FAIR, Monte Carlo) para rangos de pérdida esperada
- ☐ Contamos con modelos cuantitativos integrados en el proceso de presupuestación de ciberseguridad

BLOQUE 3 — INDICADOR R: REPRODUCIBILIDAD

(Reproducibility)

"Si algo puede salir mal una vez, puede salir mal tantas veces como se intente. El universo, en materia de ciberseguridad, es de una consistencia admirable."

P3.1 ★ — Evaluación de la Reproducibilidad de amenazas

¿Cómo evalúa su organización la facilidad con la que una amenaza puede repetirse o ejecutarse de nuevo?

- ☐ No evaluamos la reproducibilidad de forma explícita
- ☐ Asumimos que toda vulnerabilidad conocida puede reproducirse (R = 10 por defecto), como recomienda Microsoft SDL
- ☐ Evaluamos la reproducibilidad caso a caso con criterios subjetivos del analista
- ☐ Usamos la puntuación EPSS (Exploit Prediction Scoring System) del FIRST como indicador objetivo de reproducibilidad
- ☐ Correlacionamos el histórico de TTPs del MITRE ATT&CK para estimar reproducibilidad por categoría de ataque
- ☐ Tenemos un proceso formal y documentado de evaluación de reproducibilidad con criterios cuantitativos

P3.2 — Seguimiento de vulnerabilidades con exploits públicos

¿Cuánto tiempo tarda su organización en identificar que existe un exploit público disponible para una vulnerabilidad que le afecta?

- ☐ No tenemos proceso activo de seguimiento de exploits públicos
- ☐ Nos enteramos de forma reactiva (por alertas de proveedores, medios, o cuando ya hay incidentes)
- ☐ Hacemos consultas manuales periódicas (NVD, GitHub, Exploit-DB) — frecuencia aproximada: __
- ☐ Tenemos alertas automatizadas (feed CVE, INCIBE-CERT, CCN-CERT) con respuesta en días
- ☐ Tenemos vigilancia continua (< 24h) con feeds de inteligencia de amenazas en tiempo real

P3.3 — Uso del EPSS como métrica de reproducibilidad

¿Conoce y utiliza el EPSS (Exploit Prediction Scoring System) publicado por el FIRST?

- ☐ No lo conozco
- ☐ Lo conozco pero no lo uso actualmente
- ☐ Lo consulto de forma puntual para CVEs de alta criticidad
- ☐ Lo integro en mi proceso de priorización de parches como indicador de probabilidad de explotación
- ☐ Lo tengo automatizado: mi herramienta SIEM/SOAR/VM consume EPSS diariamente y lo usa en el scoring de amenazas
- ☐ Lo combino con DREAD: uso EPSS como proxy cuantitativo para las dimensiones R y E de mi evaluación

P3.4 — Gestión del ciclo de vida de vulnerabilidades

¿Cuál es el tiempo medio de remediación (MTTR) para vulnerabilidades críticas en sistemas expuestos a Internet?

- ☐ No medimos el MTTR de forma sistemática
- ☐ Más de 90 días
- ☐ Entre 30 y 90 días
- ☐ Entre 15 y 29 días
- ☐ Entre 7 y 14 días
- ☐ Menos de 7 días
- ☐ Menos de 24 horas para vulnerabilidades críticas con exploit público conocido (KEV / EPSS > 0.9)

P3.5 — Reproducibilidad en entornos OT/ICS/IoT

Si su organización opera entornos OT (Operational Technology), ICS (Industrial Control Systems) o IoT industrial, ¿cómo gestiona la reproducibilidad de amenazas en estos entornos?

- ☐ No aplica (no tenemos entornos OT/ICS/IoT relevantes)
- ☐ No diferenciamos la gestión de reproducibilidad entre IT y OT
- ☐ Somos conscientes del problema, pero no tenemos capacidad técnica específica para OT
- ☐ Aplicamos evaluación DREAD específica para OT con ajustes en la escala de Daño e impacto físico
- ☐ Seguimos guías específicas (ICS-CERT, NIST SP 800-82, CCN-STIC, Dragos Annual OT Threat Report)
- ☐ Tenemos un SOC/OT-SOC dedicado con capacidades específicas de detección y análisis en OT

BLOQUE 4 — INDICADOR E: EXPLOTABILIDAD

(Exploitability)

"En el ecosistema de la amenaza digital, la explotabilidad es la democracia del caos: cualquiera puede participar, y los requisitos de entrada no han dejado de bajar."

P4.1 ★ — Evaluación de la Explotabilidad de amenazas

¿Cómo evalúa su organización el nivel de habilidad y recursos que un atacante necesitaría para explotar una vulnerabilidad?

- ☐ No evaluamos la explotabilidad de forma explícita
- ☐ Usamos la clasificación de CVSS v4.0 (Attack Complexity: Low/High) como aproximación
- ☐ Consultamos bases de datos de exploits (Exploit-DB, CVE, Metasploit) para estimar disponibilidad de herramientas
- ☐ Realizamos análisis del perfil de atacante probable (actores estatales vs. cibercriminales vs. oportunistas)
- ☐ Integramos threat intelligence activa (feeds de dark web, ISAC sectoriales, CCN-CERT) para calibrar explotabilidad real
- ☐ Tenemos un proceso formal que correlaciona explotabilidad DREAD con métricas de CVSS, EPSS y ATT&CK

P4.2 — Impacto de la IA generativa en la Explotabilidad

¿Ha observado su organización un cambio en la barrera de entrada (explotabilidad) de ataques como consecuencia de la adopción masiva de herramientas de IA generativa por parte de los atacantes?

- ☐ No hemos observado cambios atribuibles específicamente a la IA generativa
- ☐ Sí, hemos notado mayor sofisticación en correos de phishing y mensajes de ingeniería social
- ☐ Sí, hemos detectado malware o scripts de ataque generados automáticamente con IA
- ☐ Sí, nuestros análisis de inteligencia de amenazas confirman un incremento de capacidades de atacantes de bajo perfil (script kiddies elevados por IA)
- ☐ Sí, y hemos revisado al alza nuestras puntuaciones de Explotabilidad en un porcentaje de amenazas existentes
- ☐ No disponemos de información suficiente para hacer una valoración fundamentada

P4.3 — Explotabilidad de ataques sobre sistemas de IA / LLMs

¿Ha evaluado su organización la explotabilidad de los vectores de ataque específicos sobre sistemas de Inteligencia Artificial o modelos de lenguaje (LLMs) que pueda estar utilizando?

- ☐ No utilizamos sistemas de IA en entornos productivos relevantes
- ☐ Utilizamos IA, pero no hemos realizado una evaluación específica de sus vectores de ataque
- ☐ Hemos identificado los vectores básicos (prompt injection, jailbreak) pero no los hemos valorado formalmente
- ☐ Hemos evaluado la explotabilidad de vectores sobre LLMs usando marcos como OWASP LLM Top 10
- ☐ Hemos aplicado DREAD u otro scoring cuantitativo a los vectores de ataque sobre nuestros sistemas de IA
- ☐ Tenemos un programa de red team específico para sistemas de IA con evaluación continua de explotabilidad

P4.4 — Perfiles de atacante contemplados

¿Con qué perfiles de atacante trabaja su modelado de amenazas al evaluar la Explotabilidad? (Marque todos los que apliquen)

- ☐ Usuarios internos malintencionados (insider threat)
- ☐ Oportunistas automatizados (bots, scripts de escaneo masivo)
- ☐ Cibercriminales organizados (ransomware-as-a-service, fraude financiero)
- ☐ Hacktivistas
- ☐ Competidores / espionaje industrial
- ☐ Actores patrocinados por Estados (APT)
- ☐ Investigadores de seguridad / bug hunters (amenaza no maliciosa, pero real)
- ☐ No diferenciamos perfiles de atacante en nuestros análisis

P4.5 — Reducción de la Explotabilidad como medida de mitigación

¿Qué controles implementa su organización específicamente orientados a elevar la barrera de explotabilidad (dificultad del ataque)?

(Marque todos los que apliquen)

- ☐ Autenticación multifactor (MFA) en todos los accesos privilegiados
- ☐ Segmentación de red y microsegmentación (Zero Trust)
- ☐ Gestión de vulnerabilidades con priorización basada en explotabilidad (EPSS/KEV)
- ☐ Hardening de sistemas y reducción de superficie de ataque
- ☐ Formación y simulacros de phishing para reducir explotabilidad humana
- ☐ Monitorización de dark web para detectar exploits dirigidos a nuestra organización
- ☐ Programa de bug bounty / divulgación responsable de vulnerabilidades
- ☐ Red team / pentest regular con simulación de TTPs de actores relevantes
- ☐ Deception technology (honeypots, honeytokens) para desviar ataques
- ☐ Ninguno de los anteriores de forma sistemática

BLOQUE 5 — INDICADOR A: USUARIOS AFECTADOS

(Affected Users)

"Un incidente que afecta a diez personas es un drama; uno que afecta a diez millones es una estadística... y un titular de primera plana, una multa regulatoria, y una llamada muy incómoda del Ministerio."

P5.1 ★ — Cuantificación del alcance de usuarios en escenarios de amenaza

¿Cómo cuantifica su organización el número de usuarios o ciudadanos que se verían afectados por la materialización de una amenaza?

- ☐ No cuantificamos el alcance de usuarios de forma sistemática
- ☐ Usamos categorías cualitativas (pocos / bastantes / muchos / todos)
- ☐ Estimamos un porcentaje sobre la base total de usuarios registrados o clientes
- ☐ Calculamos el número absoluto de afectados por sistema o servicio comprometido
- ☐ Estratificamos por tipo de usuario: clientes externos, empleados, ciudadanos, operadores críticos
- ☐ Para servicios esenciales: calculamos el porcentaje de la población del territorio de operación afectada

P5.2 — Umbrales de "Usuarios Afectados" para activar protocolos de respuesta

¿Tiene su organización umbrales definidos de usuarios afectados que activan protocolos específicos?

- ☐ No, no tenemos umbrales definidos
- ☐ Sí, pero solo para notificación a la AEPD (umbral de brecha de datos personales)
- ☐ Sí, también para notificación a reguladores sectoriales (CNMV, BdE, CNE...) en entidades bajo su supervisión
- ☐ Sí, tenemos umbrales vinculados a los criterios NIS2 para incidentes significativos y de gran magnitud
- ☐ Sí, y además están integrados con el Plan de Continuidad de Negocio (BCP) y el Plan de Gestión de Crisis

P5.3 — Grupos de usuarios con protección diferenciada

¿Contempla su organización criterios de ponderación adicional para grupos de usuarios especialmente protegidos?

(Marque todos los que apliquen)

- ☐ Menores de edad (usuarios de plataformas educativas, servicios al ciudadano)
- ☐ Personas mayores o con menor capacidad digital
- ☐ Pacientes (entornos sanitarios)
- ☐ Empleados en posiciones críticas con acceso privilegiado (Tier-0/Tier-1)
- ☐ Operadores de infraestructuras críticas
- ☐ No diferenciamos grupos de usuarios en nuestra evaluación de riesgo

P5.4 — Dimensión territorial y escala nacional

¿Ha evaluado alguna vez el impacto de un ciberincidente en su organización a escala territorial o sectorial (más allá del impacto en sus propios sistemas)?

- ☐ No, nuestra evaluación se limita al impacto en la propia organización
- ☐ Sí, hemos considerado el impacto en nuestra cadena de suministro inmediata
- ☐ Sí, hemos valorado el impacto en clientes o usuarios finales del servicio
- ☐ Sí, como operador esencial/importante (NIS2), hemos evaluado el impacto en la continuidad del servicio a nivel sectorial
- ☐ Sí, participamos en ejercicios de ciberseguridad nacionales (ej.: Cyber Europe, ejercicios INCIBE/CCN) donde se simula impacto territorial

P5.5 — Inventario de activos y mapa de usuarios afectados

¿Dispone su organización de un inventario actualizado que permita estimar rápidamente cuántos usuarios se verían afectados por la caída de cada sistema crítico?

- ☐ No, no tenemos inventario de activos actualizado
- ☐ Tenemos inventario de activos, pero no está vinculado a estimaciones de usuarios afectados
- ☐ Tenemos inventario con clasificación de criticidad, pero sin mapeo de usuarios por sistema
- ☐ Sí, disponemos de mapeo activo-usuario que nos permite estimar afectación en menos de 2 horas
- ☐ Sí, y el mapeo está automatizado e integrado en nuestra plataforma SIEM/SOAR/ITSM

BLOQUE 6 — INDICADOR D: DESCUBRIBILIDAD

(Discoverability)

"La ilusión de que nadie encontrará la vulnerabilidad porque está bien escondida es el autoengaño más cómodo —y el más peligroso— del ecosistema de seguridad."

P6.1 ★ — Enfoque sobre la Descubribilidad

¿Cuál es el enfoque de su organización respecto a la dimensión de Descubribilidad al evaluar amenazas?

- ☐ No la consideramos explícitamente en nuestra evaluación de riesgos
- ☐ La asumimos siempre en valor máximo (D = 10): cualquier vulnerabilidad será eventualmente descubierta
- ☐ La evaluamos caso a caso: distinguimos entre vulnerabilidades públicamente conocidas y las que solo nosotros conocemos
- ☐ Usamos inteligencia de dark web / threat intel para medir si hay interés activo de atacantes en nuestras vulnerabilidades específicas
- ☐ Trabajamos con la variante DREAD-D (sin esta dimensión) para evitar incentivos hacia la "seguridad por oscuridad"
- ☐ Calibramos la Descubribilidad en función de los actores de amenaza relevantes para nuestro sector

P6.2 — Vigilancia digital y monitorización de Descubribilidad

¿Dispone su organización de capacidades activas de vigilancia digital para detectar si sus vulnerabilidades o sistemas están siendo explorados por actores maliciosos?

- ☐ No, no tenemos capacidades de vigilancia digital activa
- ☐ Monitorizamos alertas de CCN-CERT, INCIBE-CERT y otros CSIRTs de confianza
- ☐ Tenemos suscripción a servicios de threat intelligence comerciales (ej.: Mandiant, Recorded Future, CrowdStrike)
- ☐ Hacemos búsquedas periódicas en Shodan/Censys/FOFA sobre nuestra superficie de exposición pública
- ☐ Monitorizamos foros de dark web, Telegram y mercados underground para detectar menciones de nuestra organización o sector
- ☐ Tenemos un programa de Attack Surface Management (ASM) continuo y automatizado

P6.3 — Pruebas de Descubribilidad mediante ejercicios red team

¿Realiza su organización ejercicios de simulación de ataque (red team / pentest) que incluyan específicamente la evaluación de cuán fácil es descubrir sus vulnerabilidades desde el exterior?

- ☐ No realizamos ejercicios de red team ni pentest de forma regular
- ☐ Realizamos pentests anuales de alcance limitado (scope muy acotado)
- ☐ Realizamos pentests anuales con alcance amplio sobre sistemas críticos
- ☐ Realizamos ejercicios de red team continuos o semianuales con simulación de TTPs de actores reales
- ☐ Tenemos un programa de purple team permanente (colaboración red + blue team)
- ☐ Participamos en el Programa de Bug Bounty / Divulgación Coordinada de Vulnerabilidades (VDP)

P6.4 — Gestión de la exposición pública (Attack Surface)

¿Conoce su organización en tiempo real qué activos están expuestos públicamente a Internet y cuáles tienen vulnerabilidades descubribles externamente?

- ☐ No tenemos visibilidad de nuestra exposición pública de forma continua
- ☐ Hacemos inventarios manuales periódicos (frecuencia: ____)
- ☐ Usamos herramientas de escaneo programado (Nessus, Qualys, OpenVAS, etc.)
- ☐ Tenemos una solución de Attack Surface Management (ASM) que nos da visibilidad continua
- ☐ Integramos ASM con nuestra evaluación de riesgo DREAD para actualizar scores de Descubribilidad en tiempo real

BLOQUE 7 — INTEGRACIÓN, AUTOMATIZACIÓN Y MADUREZ DEL SCORING DREAD

"Un score calculado a mano, con un café en la mano y buenas intenciones, vale lo que vale. Un score automatizado, calibrado y auditado vale lo que cuesta hacerlo bien: bastante más."

P7.1 ★ — Nivel de automatización del scoring de riesgos

¿En qué medida está automatizado el proceso de scoring de amenazas y vulnerabilidades en su organización?

- ☐ Manual: todos los scores se asignan por expertos humanos sin apoyo de herramientas específicas
- ☐ Semi-manual: usamos plantillas y hojas de cálculo para estandarizar el proceso
- ☐ Parcialmente automatizado: algunas fuentes (ej.: CVSS, EPSS) se importan automáticamente; el juicio humano completa el score
- ☐ Mayormente automatizado: las herramientas SIEM/VM/SOAR calculan scores de riesgo automáticamente; los humanos validan
- ☐ Totalmente automatizado: sistema de scoring en tiempo real con mínima intervención humana; los humanos actúan sobre alertas

P7.2 — Herramientas utilizadas para el scoring de amenazas

¿Qué herramientas o plataformas utiliza para apoyar la evaluación y scoring de amenazas? (Marque todas las que apliquen)

- ☐ Hojas de cálculo (Excel, Google Sheets) con plantillas propias
- ☐ Herramienta PILAR (CCN-CERT) / MAGERIT
- ☐ SimpleRisk, ThreatModeler, IriusRisk u otra herramienta de modelado de amenazas
- ☐ Qualys, Tenable, Rapid7 (gestión de vulnerabilidades con scoring integrado)
- ☐ SIEM (Splunk, Microsoft Sentinel, QRadar, Elastic SIEM...) con correlación de riesgos
- ☐ Plataformas de Threat Intelligence (MISP, OpenCTI, ThreatConnect...)
- ☐ XDR / EDR con scoring de incidentes automático
- ☐ Plataformas de GRC (RSA Archer, ServiceNow GRC, OneTrust...)
- ☐ Soluciones de IA/ML específicas para scoring de amenazas
- ☐ Ninguna herramienta específica

P7.3 — Integración de DREAD con Machine Learning

¿Conoce o ha explorado la integración de DREAD con técnicas de machine learning para automatizar la clasificación y scoring de amenazas?

- ☐ No, no lo he considerado
- ☐ He leído sobre ello pero no lo hemos explorado en nuestra organización
- ☐ Lo hemos evaluado internamente como posibilidad futura
- ☐ Hemos realizado una prueba de concepto (PoC) o piloto
- ☐ Tenemos implementada una solución de ML integrada con nuestro proceso de scoring de amenazas
- ☐ Somos referencia en la industria en el uso de ML para scoring de amenazas

P7.4 — Frecuencia de revisión y actualización de scores

¿Con qué frecuencia se revisan y actualizan los scores de riesgo de las amenazas identificadas en su organización?

- ☐ No se revisan de forma sistemática (persisten hasta que se resuelve el incidente o se olvidan)
- ☐ Trimestralmente o con menor frecuencia
- ☐ Mensualmente
- ☐ Semanalmente
- ☐ Diariamente (con apoyo de herramientas automatizadas)
- ☐ En tiempo real (actualización continua mediante feeds automáticos)

P7.5 — Consistencia inter-analista en el scoring

¿Ha evaluado su organización el grado de consistencia en los scores de riesgo asignados por diferentes analistas para la misma amenaza?

- ☐ No, nunca lo hemos evaluado
- ☐ Hemos observado inconsistencias, pero no hemos tomado medidas formales
- ☐ Hemos realizado ejercicios de calibración de criterios entre el equipo de seguridad
- ☐ Tenemos guías y rúbricas detalladas por dimensión para reducir la variabilidad inter-analista
- ☐ Hacemos auditorías periódicas de consistencia y los resultados informan la actualización de nuestras rúbricas
- ☐ Usamos herramientas que fuerzan criterios objetivos (ej.: AHP, lógica difusa) reduciendo la dependencia del juicio individual

BLOQUE 8 — COMPARATIVA CON OTROS FRAMEWORKS Y MADUREZ INTEGRAL

P8.1 ★ — Uso combinado de frameworks

¿Cómo combina su organización DREAD con otros marcos de evaluación de riesgos?

- ☐ Usamos un único framework (indicar cuál: ____)
- ☐ DREAD + CVSS: usamos CVSS para el scoring técnico y DREAD para el impacto en negocio
- ☐ DREAD + EPSS: EPSS informa la probabilidad de explotación que alimenta R y E de DREAD
- ☐ DREAD + FAIR: DREAD prioriza y FAIR cuantifica financieramente el riesgo
- ☐ DREAD + MITRE ATT&CK: ATT&CK informa los TTPs y DREAD puntúa su impacto
- ☐ Stack completo: DREAD + CVSS + EPSS + FAIR + ATT&CK de forma integrada
- ☐ No usamos DREAD; nuestro stack no lo incluye

P8.2 — Alineación con ENS (Esquema Nacional de Seguridad)

¿Está su organización sujeta al ENS y ha alineado su metodología de evaluación de riesgos con las categorías de seguridad del ENS (ALTA / MEDIA / BÁSICA)?

- ☐ No estamos sujetos al ENS
- ☐ Estamos sujetos, pero no hemos alineado explícitamente nuestra metodología de scoring
- ☐ Hemos mapeado parcialmente nuestros niveles de riesgo con las categorías ENS
- ☐ Tenemos un mapeo completo y documentado entre DREAD, CVSS y categorías ENS
- ☐ Contamos con certificación ENS y la evaluación de riesgos es auditada externamente

P8.3 — Alineación con NIS2 / Ley de Ciberseguridad española

¿Ha adaptado su proceso de evaluación de riesgos a los requisitos del Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad (España, enero 2025) que transpone NIS2?

- ☐ No estamos sujetos a NIS2 / no conocemos los requisitos
- ☐ Conocemos los requisitos pero aún no hemos adaptado nuestros procesos
- ☐ Hemos iniciado el proceso de adaptación
- ☐ Hemos adaptado nuestros procesos de gestión de riesgos y notificación de incidentes
- ☐ Estamos completamente alineados con NIS2 y preparados para las auditorías del CNCS

P8.4 — Alineación con DORA (Sector financiero)

(Solo para entidades del sector financiero, seguros o TIC que prestan servicios a dicho sector)

¿Ha integrado los requisitos de resiliencia operacional digital de DORA en su metodología de evaluación de riesgos y en la puntuación de Daño DREAD?

- ☐ No aplica a nuestra organización
- ☐ Estamos en proceso de análisis de brechas (gap analysis)
- ☐ Hemos identificado los riesgos TIC que DORA exige gestionar y los hemos incorporado a nuestro scoring
- ☐ Tenemos un marco DORA-compliant con evaluación de riesgo de terceros (proveedores TIC) integrada
- ☐ Tenemos el marco auditado externamente y los resultados han sido comunicados al regulador (BdE / CNMV)

P8.5 — Indicadores KPI/KRI de ciberseguridad formalizados

¿Tiene su organización definidos indicadores clave de rendimiento (KPI) y de riesgo (KRI) de ciberseguridad que reporta regularmente a la alta dirección?

- ☐ No, no tenemos KPIs ni KRIs de ciberseguridad formalizados
- ☐ Tenemos algunos indicadores operativos (ej.: número de incidentes), pero no reportamos a la alta dirección
- ☐ Reportamos incidentes a la alta dirección pero sin métricas cuantitativas de riesgo
- ☐ Tenemos un cuadro de mando básico con KPIs de ciberseguridad que se presenta al Comité de Dirección
- ☐ Tenemos un dashboard completo con KPIs, KRIs y métricas DREAD/CVSS/EPSS reportado al Consejo de Administración
- ☐ El Consejo de Administración tiene formación específica en ciberseguridad y revisa los indicadores de riesgo activamente

BLOQUE 9 — INFRAESTRUCTURA CRÍTICA Y ESCALA NACIONAL

P9.1 ★ — Relevancia de la escala nacional en la evaluación de riesgos

Si su organización opera infraestructura o servicios con impacto potencial a escala nacional o regional, ¿incorpora esta dimensión en su evaluación de riesgos?

- ☐ No aplica: no operamos infraestructura con impacto a escala nacional
- ☐ Sí, pero la dimensión nacional solo la considera el regulador, no nuestra evaluación interna
- ☐ Sí, en nuestros escenarios de riesgo consideramos el impacto potencial en la continuidad del servicio a ciudadanos
- ☐ Sí, calculamos el número máximo de ciudadanos / servicios afectados en nuestros peores escenarios
- ☐ Sí, participamos en el sistema de gestión de riesgos nacionales coordinado por el CCN-CERT / INCIBE-CERT / CNPIC

P9.2 — Coordinación con organismos nacionales de ciberseguridad

¿Con qué frecuencia e intensidad coordina su organización con los organismos nacionales de ciberseguridad españoles?

- ☐ No tenemos coordinación activa con ningún organismo nacional
- ☐ Recibimos alertas de INCIBE-CERT o CCN-CERT pero no hay interacción bidireccional
- ☐ Notificamos incidentes cuando estamos obligados por normativa
- ☐ Tenemos coordinación regular (trimestral o más frecuente) con CCN-CERT, INCIBE-CERT o CNPIC
- ☐ Somos miembros activos de algún ISAC sectorial o grupo de coordinación de la ciberseguridad nacional
- ☐ Colaboramos en ejercicios nacionales o europeos de ciberseguridad (Cyber Europe, ENISA exercises...)

P9.3 — Resiliencia operacional ante incidentes de gran escala

¿Dispone su organización de un Plan de Continuidad de Negocio (BCP) y Plan de Recuperación ante Desastres (DRP) probados específicamente contra escenarios de ciberincidente de gran escala?

- ☐ No disponemos de BCP/DRP formalizados
- ☐ Tenemos BCP/DRP, pero no contemplan específicamente escenarios de ciberincidente
- ☐ Tenemos planes que contemplan ciberincidentes, pero no los hemos probado
- ☐ Realizamos pruebas anuales (tabletop exercises) de nuestros planes
- ☐ Realizamos simulacros técnicos completos (failover real) con escenarios de ciberincidente al menos anualmente
- ☐ Nuestros planes están integrados con el esquema de coordinación nacional (CCN-CERT, INCIBE-CERT, CNI)

BLOQUE 10 — CULTURA, FORMACIÓN Y RECURSOS

P10.1 ★ — Cultura de ciberseguridad organizativa

¿Cómo describiría el nivel de cultura de ciberseguridad en su organización?

- ☐ La ciberseguridad es vista como un problema exclusivo del departamento de TI
- ☐ Hay concienciación básica, pero el comportamiento de los empleados sigue siendo el mayor vector de riesgo
- ☐ Existe una cultura de seguridad en toda la organización, con formación regular para todos los empleados
- ☐ La ciberseguridad está integrada en los procesos de negocio; los equipos no técnicos entienden su papel
- ☐ Somos una organización "security-first": la seguridad es un valor competitivo, no solo un requisito regulatorio

P10.2 — Formación en metodologías de evaluación de riesgos

¿Reciben formación específica los profesionales que participan en la evaluación de riesgos (incluyendo DREAD, CVSS, threat modeling) sobre metodologías cuantitativas?

- ☐ No, la formación en evaluación de riesgos es autodidacta o informal
- ☐ Sí, formación básica en el marco de la certificación CISSP, CISM, ISO 27001 o equivalente
- ☐ Sí, formación específica en threat modeling (STRIDE, PASTA, DREAD)
- ☐ Sí, formación avanzada en cuantificación del riesgo (FAIR, CRISC, modelos actuariales)
- ☐ Sí, formación en herramientas de ML/IA aplicadas al análisis de amenazas

P10.3 — Presupuesto de ciberseguridad como porcentaje del gasto TI

¿Qué porcentaje aproximado del presupuesto total de TI de su organización se destina a ciberseguridad?

- ☐ Menos del 5%
- ☐ Entre el 5% y el 10%
- ☐ Entre el 10% y el 15%
- ☐ Entre el 15% y el 20%
- ☐ Más del 20%
- ☐ No conocemos este dato / no está desagregado

P10.4 — Brecha de talento en ciberseguridad

¿Sufre su organización escasez de personal cualificado en ciberseguridad que afecte a su capacidad de evaluar y gestionar riesgos?

- ☐ No, tenemos el equipo necesario con las competencias requeridas
- ☐ Sí, tenemos plazas vacantes que no somos capaces de cubrir
- ☐ Sí, dependemos significativamente de proveedores externos (MSSPs) para compensar la brecha
- ☐ Sí, la brecha de talento es uno de nuestros principales riesgos de ciberseguridad
- ☐ Lo mitigamos con automatización y herramientas de IA que reducen la dependencia del factor humano

BLOQUE 11 — TENDENCIAS Y VISIÓN PROSPECTIVA

P11.1 — Evolución del modelo DREAD en su organización

¿Cómo prevé que evolucionará el uso del modelo DREAD (o sus extensiones) en su organización en los próximos 24 meses?

- ☐ No prevemos adoptarlo / seguiremos sin usarlo
- ☐ Mantendremos el uso actual sin cambios significativos
- ☐ Prevemos formalizar su uso con documentación y rúbricas de scoring
- ☐ Prevemos integrarlo con otras herramientas y frameworks en un stack de evaluación más maduro
- ☐ Prevemos automatizarlo parcial o totalmente con soporte de ML/IA
- ☐ Prevemos usarlo como base para el reporting de riesgo a nivel de Consejo de Administración y reguladores

P11.2 — Principales amenazas que preocupan para 2026-2027

¿Cuáles son las tres amenazas que mayor preocupación generan en su organización para los próximos 18 meses?

(Marque un máximo de tres)

- ☐ Ransomware (extorsión de datos / doble extorsión)
- ☐ Ataques a la cadena de suministro (software / proveedores TIC)
- ☐ Espionaje por actores estatales (APT)
- ☐ Ataques a sistemas de IA / LLMs
- ☐ Explotación de vulnerabilidades en IoT / OT / ICS
- ☐ Fraude financiero / Business Email Compromise (BEC)
- ☐ Ataques a infraestructura en la nube (misconfiguraciones, CSPM)
- ☐ Amenazas post-cuánticas (descifrado de comunicaciones cifradas)
- ☐ Hacktivismo y ataques de denegación de servicio distribuido (DDoS) motivados políticamente
- ☐ Desinformación asistida por IA con impacto en la reputación corporativa

P11.3 — Valoración del marco DREAD para el análisis de amenazas nacionales

En su opinión, ¿es el marco DREAD adecuado como instrumento de evaluación de amenazas a escala nacional territorial (ej.: para el futuro CNCS)?

- ☐ No, DREAD es demasiado simple y subjetivo para aplicaciones de gobernanza nacional
- ☐ Podría serlo si se extiende con ponderaciones AHP y métricas objetivas complementarias
- ☐ Sí, con la variante ponderada y reescalado de la dimensión "Usuarios Afectados" al territorio
- ☐ Sí, pero siempre como parte de un stack más amplio (DREAD + CVSS + EPSS + FAIR)
- ☐ Sería más adecuado desarrollar un framework nacional propio adaptado al contexto español
- ☐ No tengo suficiente información para valorarlo

BLOQUE 12 — PREGUNTAS ABIERTAS

(Respuestas de texto libre. Opcional, pero de gran valor para el análisis cualitativo)

P12.1 — Lección aprendida más valiosa

¿Cuál ha sido la lección más valiosa que su organización ha extraído de un incidente de ciberseguridad en los últimos tres años en relación con la evaluación de amenazas (Daño, Reproducibilidad, Explotabilidad, Alcance, Descubribilidad)?

(Espacio libre — máx. 300 palabras)

P12.2 — Mayor obstáculo para una evaluación cuantitativa de riesgos

¿Cuál es, en su experiencia, el principal obstáculo para implementar una evaluación cuantitativa y sistemática del riesgo de ciberseguridad en su organización?

(Espacio libre — máx. 200 palabras)

P12.3 — Propuesta de mejora al marco DREAD

Si pudiera modificar o extender el marco DREAD para hacerlo más útil en el contexto de la ciberseguridad española de 2026, ¿qué cambiaría o añadiría?

(Espacio libre — máx. 200 palabras)

P12.4 — Comentarios adicionales

¿Hay algún aspecto de la evaluación de riesgos de ciberseguridad en su organización que no haya sido cubierto en esta encuesta y que considere relevante?

(Espacio libre — máx. 200 palabras)

DECLARACIÓN DE CONSENTIMIENTO

Al cumplimentar y enviar esta encuesta, confirmo que:

1. Soy el/la responsable o estoy autorizado/a para proporcionar esta información en nombre de mi organización.
2. Comprendo que los datos serán tratados de forma confidencial y únicamente para los fines de investigación descritos.
3. Consiento el tratamiento de los datos proporcionados de conformidad con el RGPD (Reglamento UE 2016/679) y la Ley Orgánica 3/2018 de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD).

Fecha de cumplimentación: _____

Firma (versión impresa): _____

Kit de Encuesta DREAD · Investigación sobre Métricas de Ciberseguridad · España 2025–2026

Basado en: INCIBE Balance 2025, ENISA ETL 2025, CCN-CERT IA-04/24, Anteproyecto LCGC (enero 2025), NIS2, ENS, DORA